TP : Pentesting d’une Application Web avec Kali Linux

Objectif :

Apprendre à utiliser Kali Linux et Metasploit pour effectuer un test d’intrusion sur une application web vulnérable en explorant des vulnérabilités courantes comme les injections SQL, XSS et les failles de gestion de session.

Étape 1 : Préparation de l’Environnement

1. Configurer les machines :

- Lancez Kali Linux (machine attaquante).

- Assurez-vous que la machine cible (ex : Metasploitable2 ou DVWA) est sur le même réseau.

- Vérifiez la connectivité et préciser l'outil

2. *Activer DVWA* (si utilisée) :

- Accédez à l'interface de DVWA via un navigateur : faite le capture.

- Connectez-vous avec les identifiants :

  - Username: admin

  - Password: password

- Configurez le niveau de sécurité sur "Low".

Étape 2 : Scanning des Vulnérabilités

1. Lancer OWASP ZAP depuis Kali :

- Applications > Web Application Analysis > OWASP ZAP.

- Configurez ZAP pour capturer le trafic entre votre navigateur et la cible.

- Identifiez les endpoints vulnérables, comme les formulaires ou les paramètres GET/POST.

2. *Scanner l’Application* :

- Utilisez la fonction Active Scan pour découvrir des vulnérabilités comme SQL Injection ou XSS.

- Identifiez les services ouverts (port 80 ou 443 pour les applications web).

Évaluation des Étudiants

- Compréhension et application des outils.

- Qualité des analyses et des rapports.

- Respect des bonnes pratiques éthiques et légales.

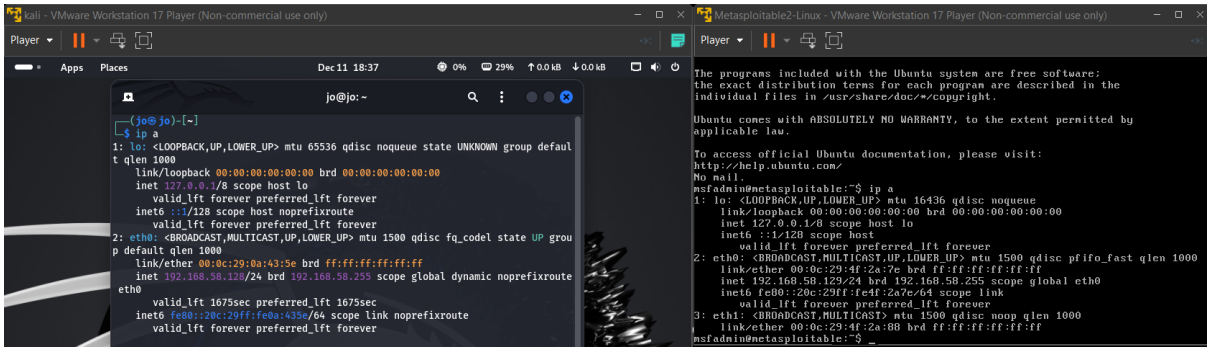
PROJET

Étape 1 : Préparation de l’Environnement

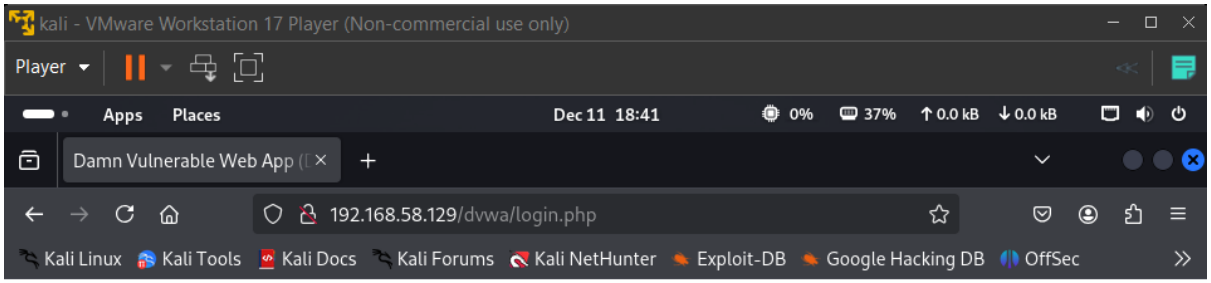
ALORS POUR l'architecture nous allons utiliser une machine kali linux pour faire l’attaque et de notre machine metasploit pour l'application web.

Nous allons explorer des vulnérabilités courantes comme les injections SQL, XSS et les failles de gestion de session.

Les machines sont dans le même réseaux



Activation de DVWA



DVWA

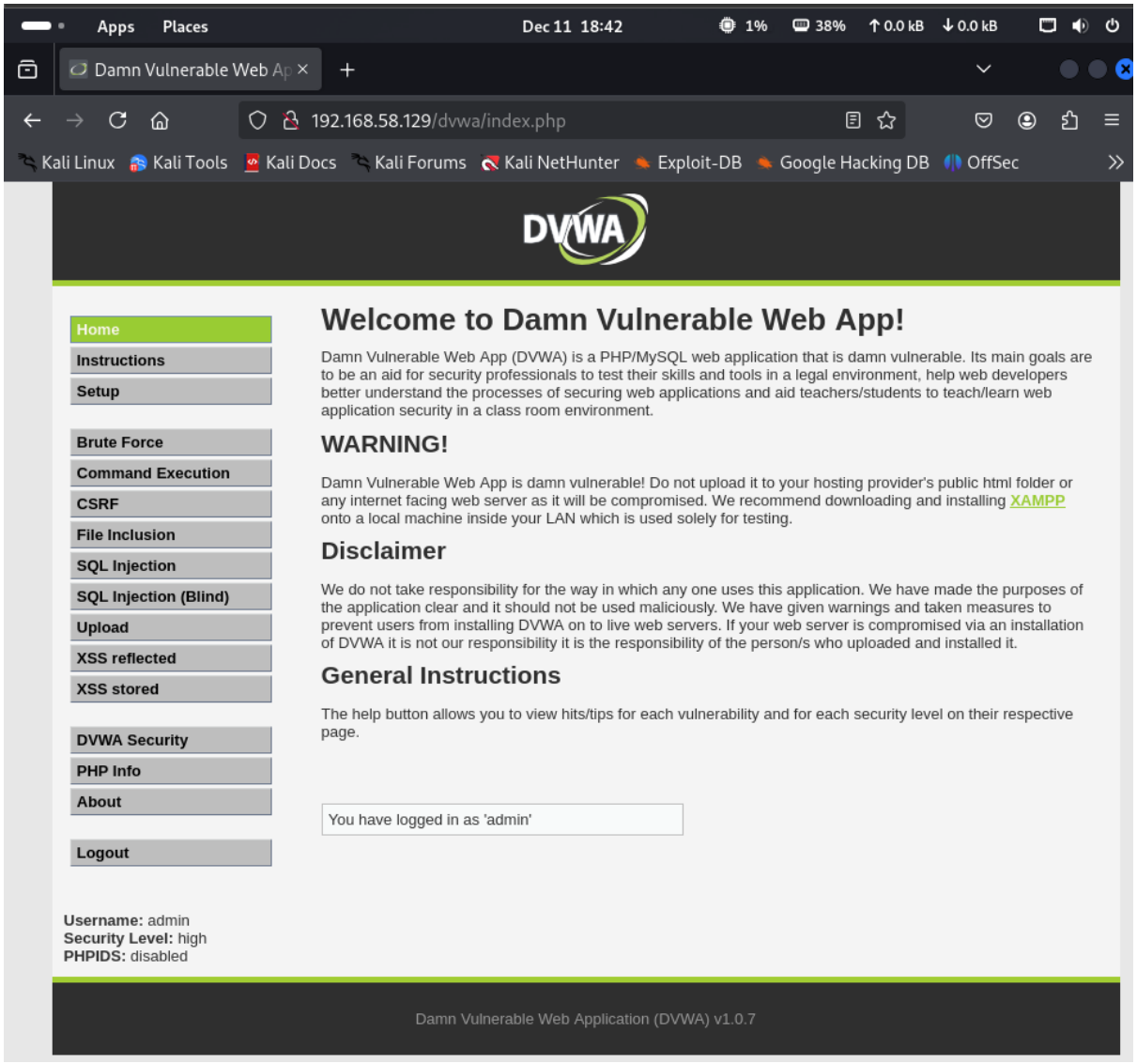
Username

Password

Login

Damn Vulnerable Web Application (DVWA) is a RandomStorm OpenSource project

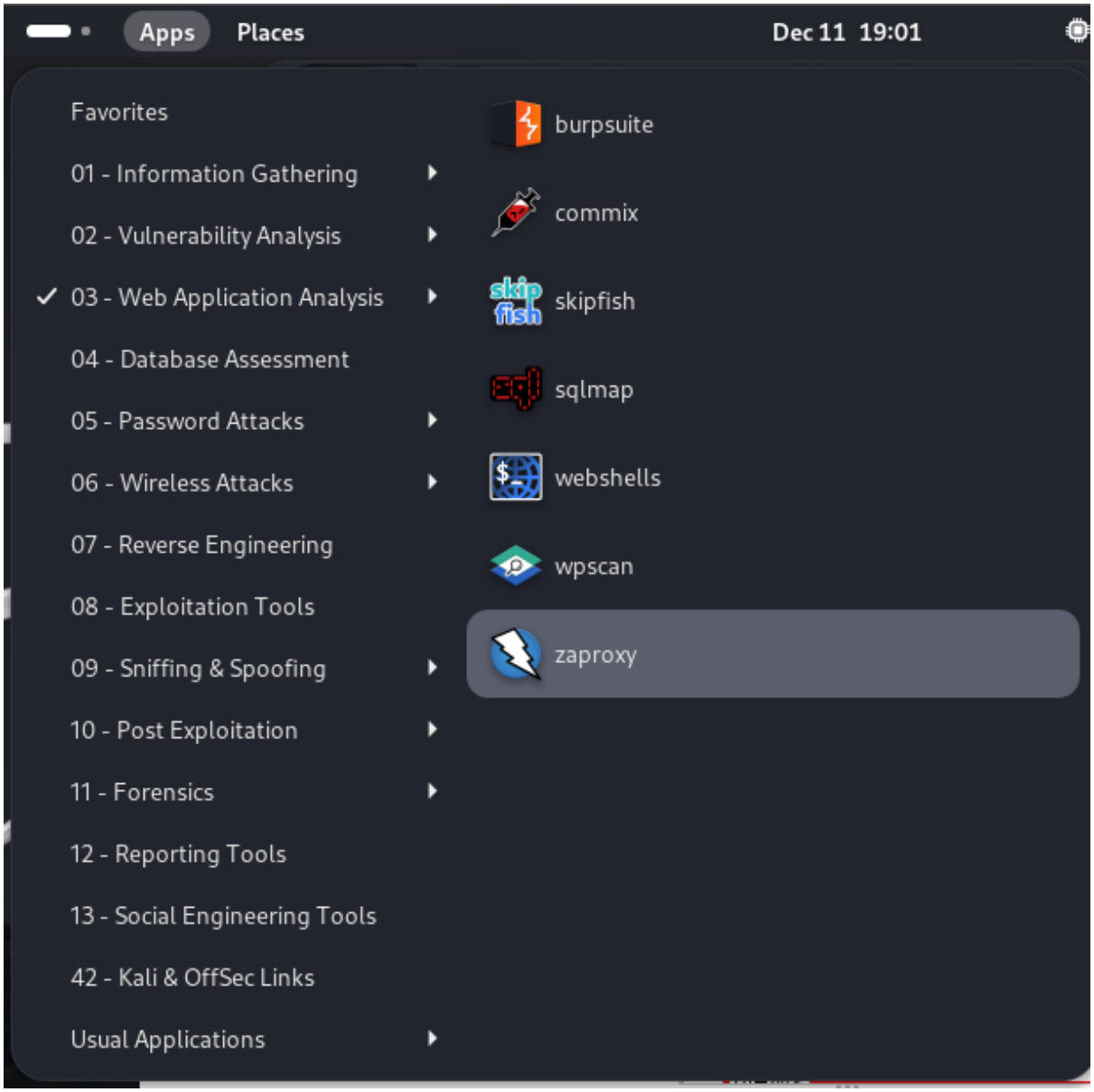
Hint: default username is 'admin' with password 'password'



nous allons maintenant regler le securite en mode faible pour simuler un environnement vulnerable

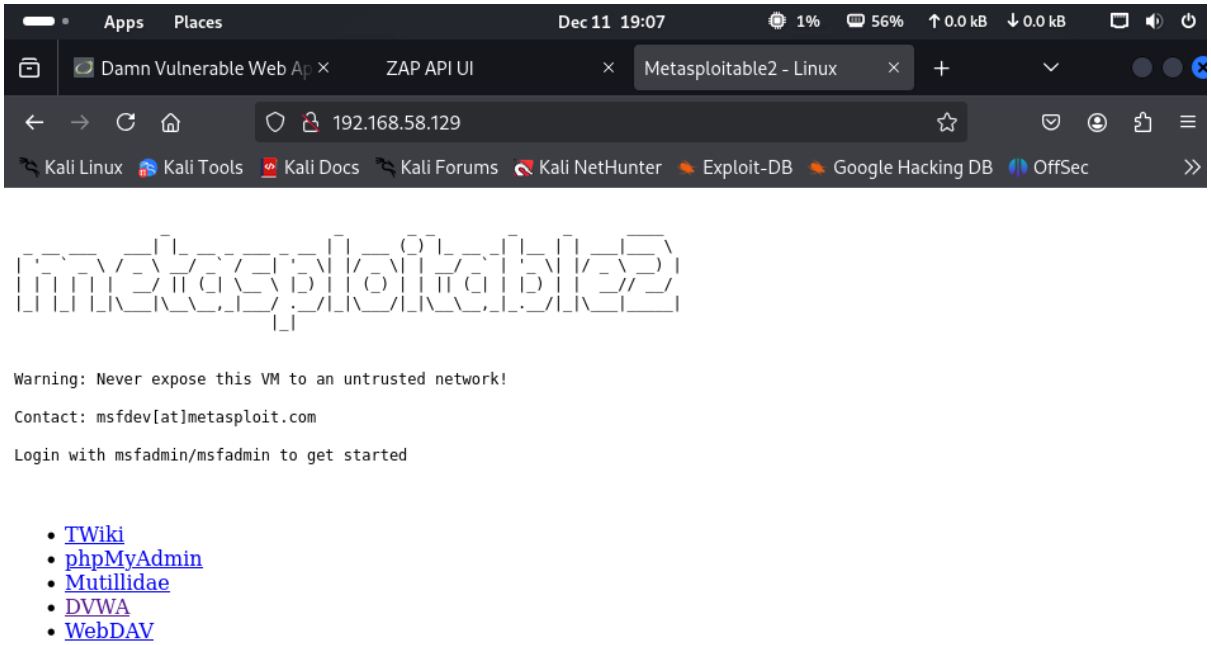
Étape 2 : Scanning des Vulnérabilités

Nous allons lancer owasp via `applications > Web Application Analysis > zaproxy`

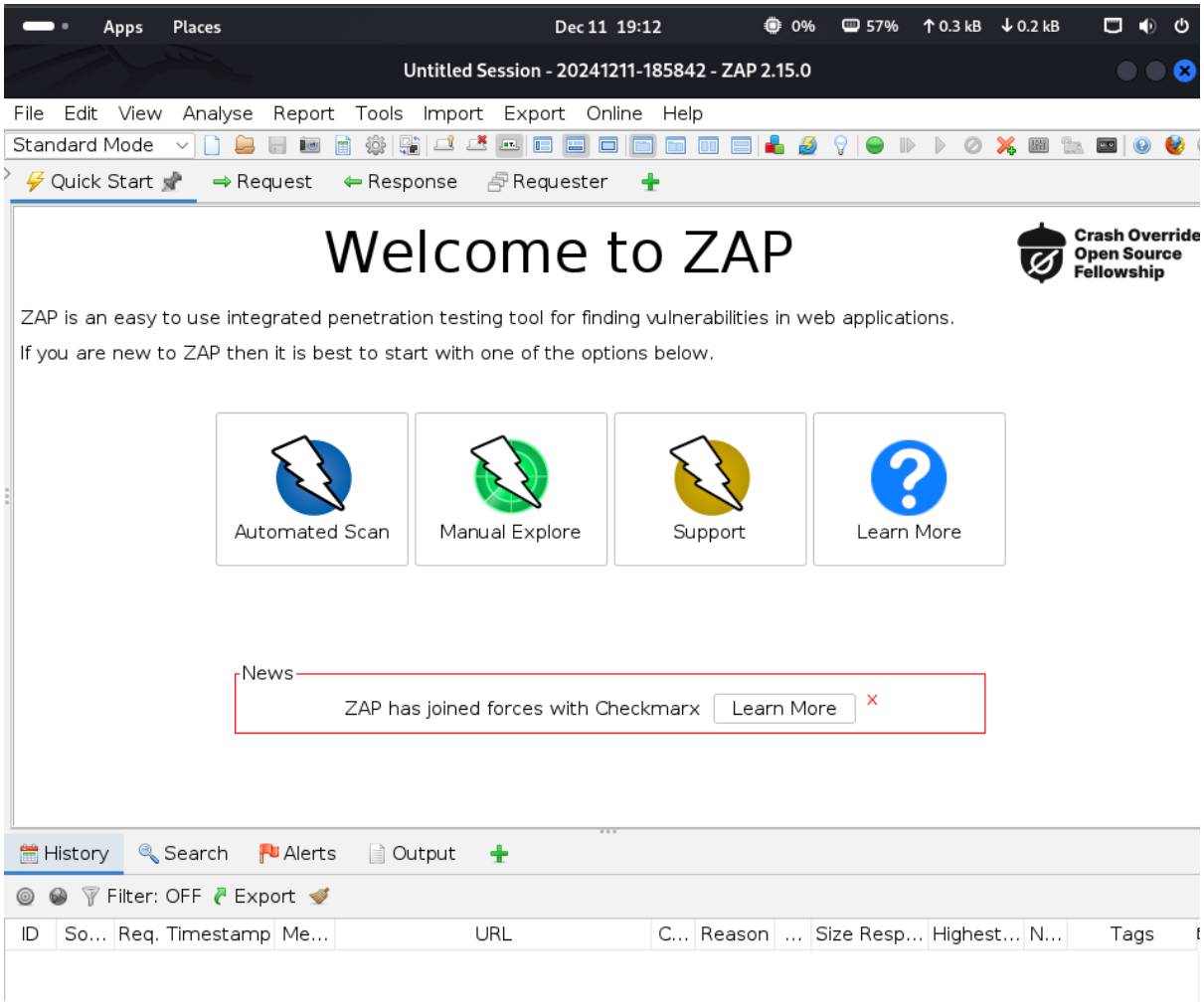


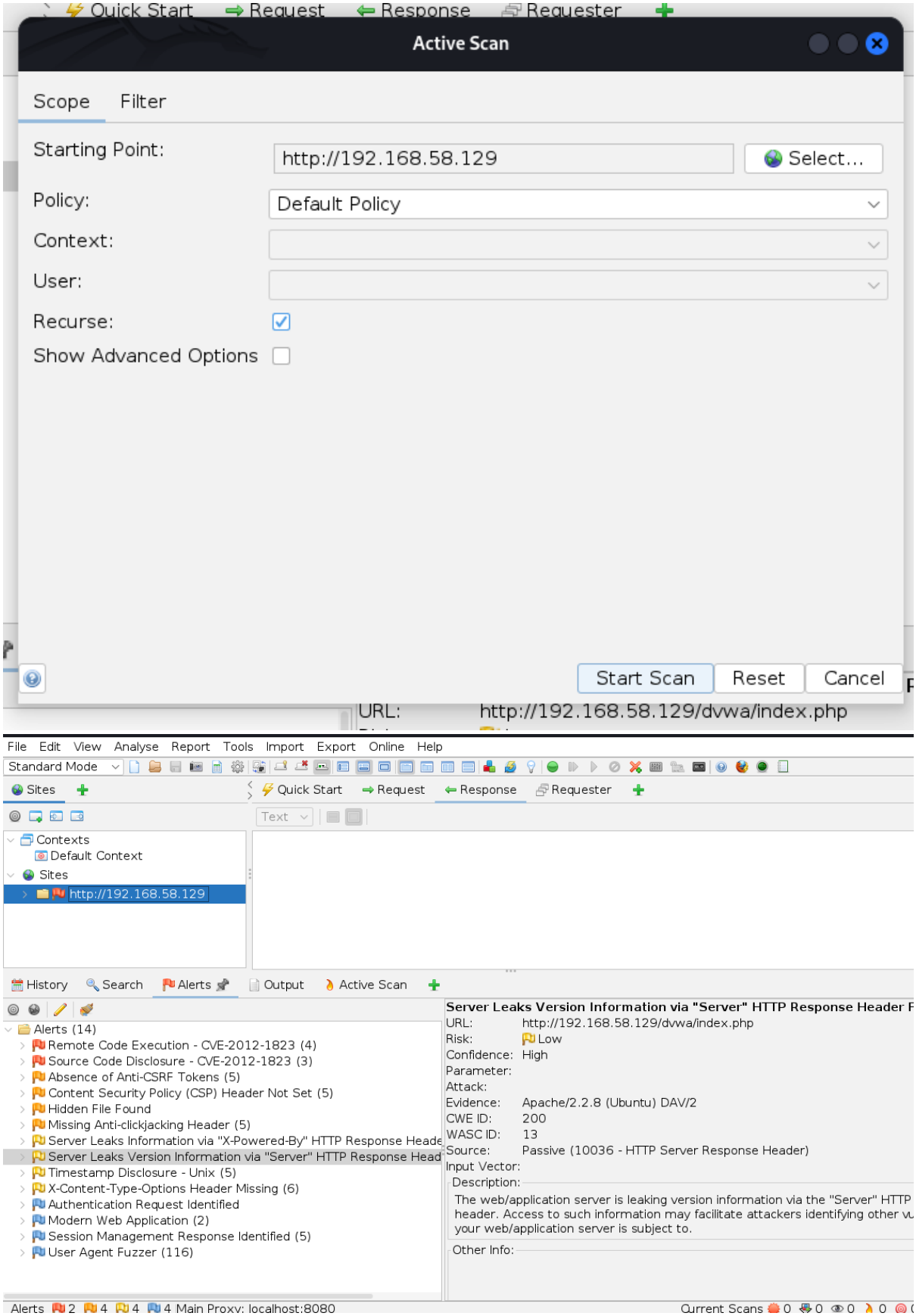
Ensuite nous allons configurer un proxy dans notre navigateur pour intercepter le trafic web. Par défaut le proxy est `127.0.0.1:8080`.

Ensuite nous allons naviguer sur le site de la machine cible pour permettre après a owasp le scan

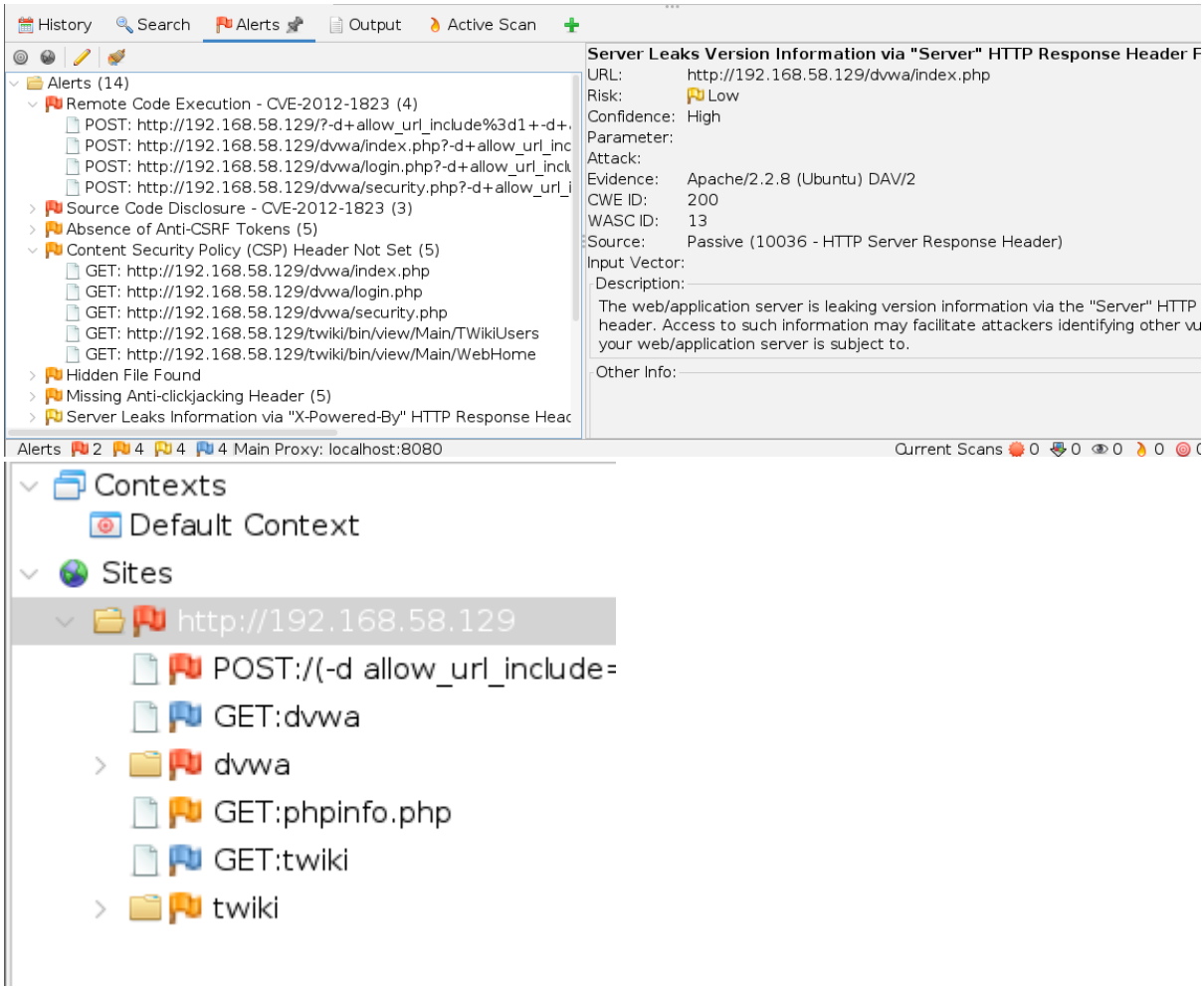


Apres avoir naviguer nous allions Scanner actif avec OWASP ZAP. Nous allons utiliser la fonction **Active Scan** pour automatiser la recherche des vulnérabilités.

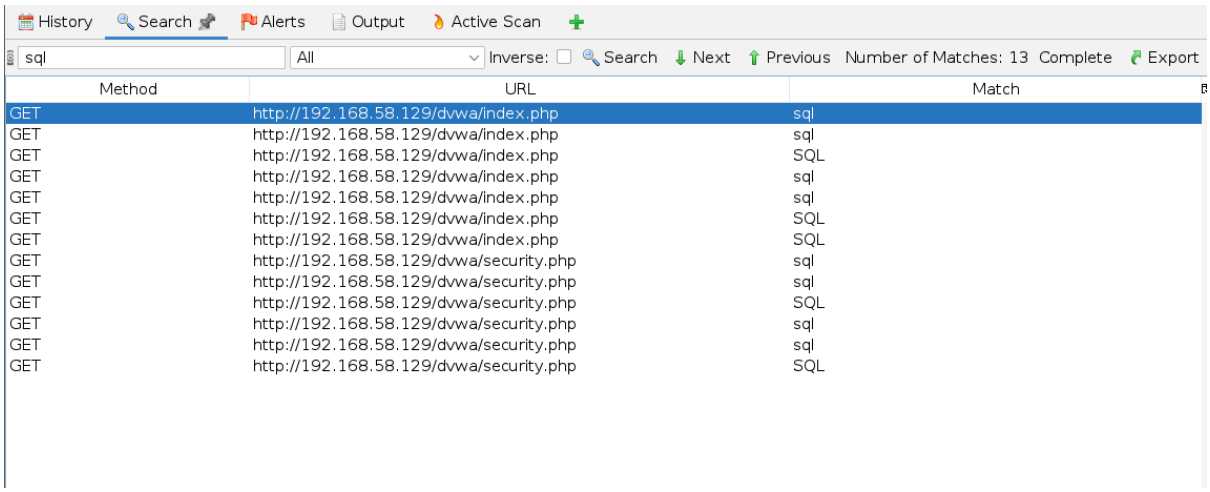

Apps
Places
Dec 11 19:12
0%
57%
0.3 kB
0.2 kB
Untitled Session - 20241211-185842 - ZAP 2.15.0
File
Edit
View
Analyse
Report
Tools
Import
Export
Online
Help
Standard Mode
Quick Start
Request
Response
Requester
Welcome to ZAP
Crash Override Open Source Fellowship
ZAP is an easy to use integrated penetration testing tool for finding vulnerabilities in web applications.
If you are new to ZAP then it is best to start with one of the options below.
Automated Scan
Manual Explore
Support
Learn More
News
ZAP has joined forces with Checkmarx
Learn More
History
Search
Alerts
Output
Filter: OFF
Export
ID
So...
Req. Timestamp
Me...
URL
C...
Reason
...
Size Resp...
Highest...
N...
Tags



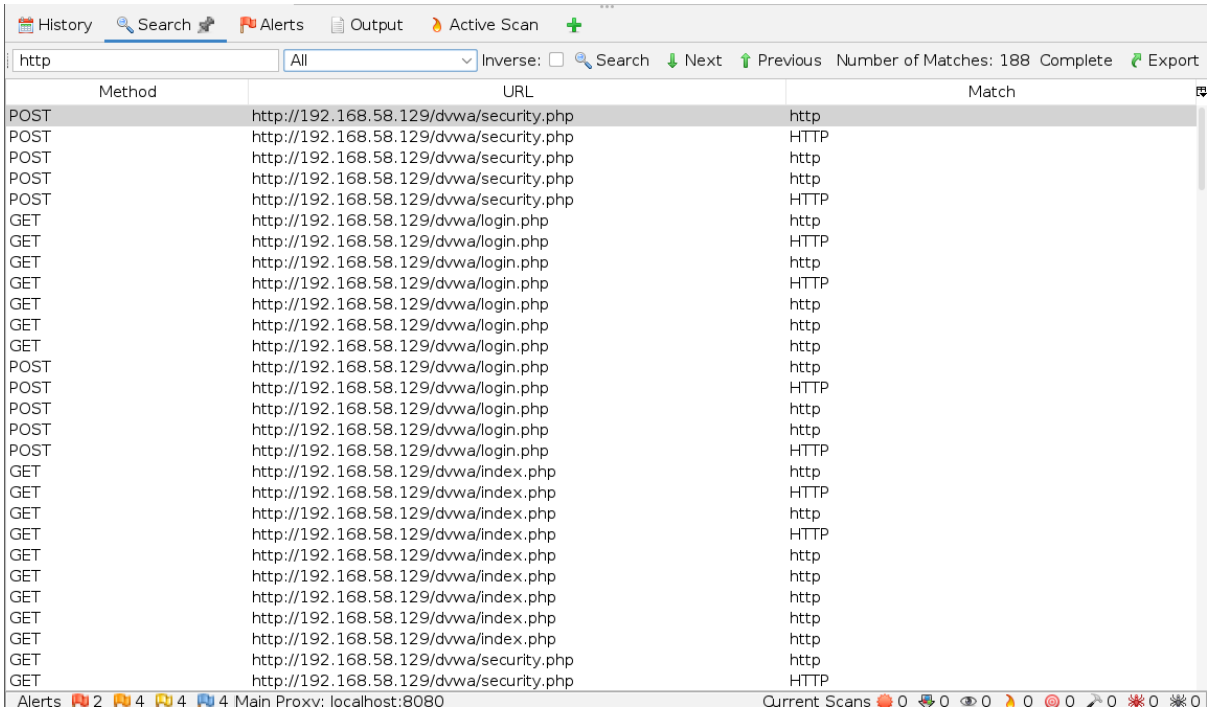
Nous allons Identifiez les endpoints vulnérables, comme les formulaires ou les paramètres GET/POST.



Ensuite nous allons utilisez la fonction Active Scan pour découvrir des vulnérabilités comme SQL Injection ou XSS.

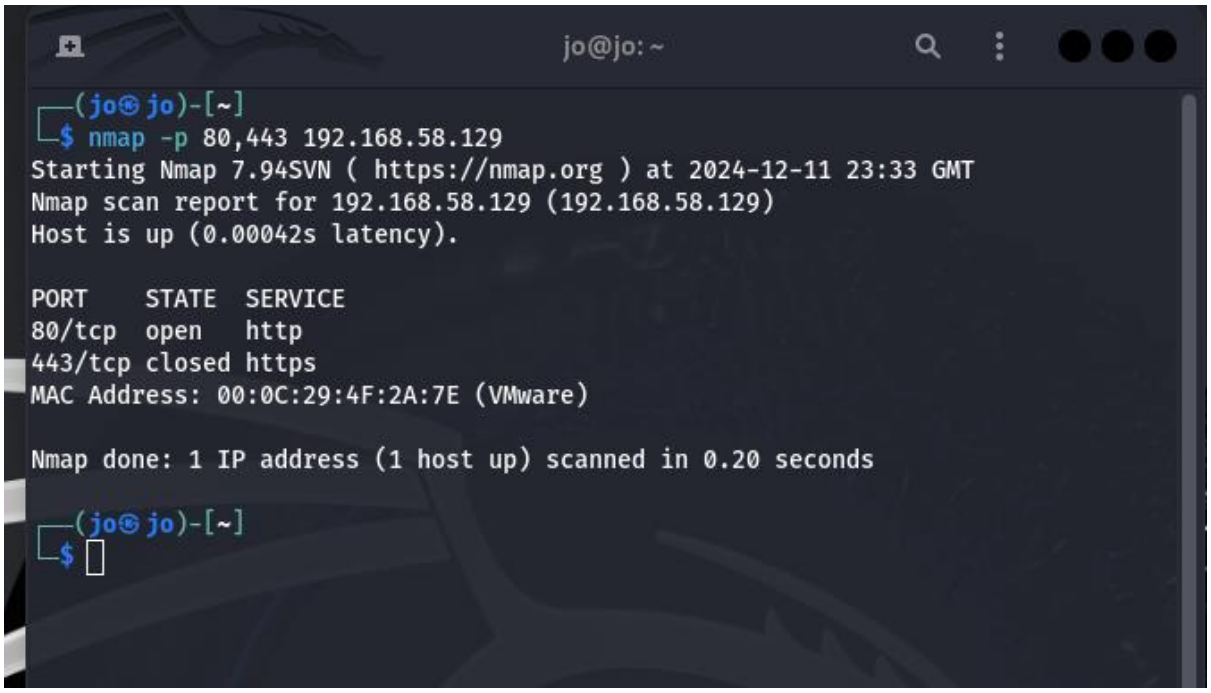


Apres nous allons verifier les port ouvert http ou https



Sinon comme atlernative pour analyser les ports nmap est aussi





ici la commande indique que le port 80/tcp(http) est ouvert alors que le port 443/tcp(https)est ferme